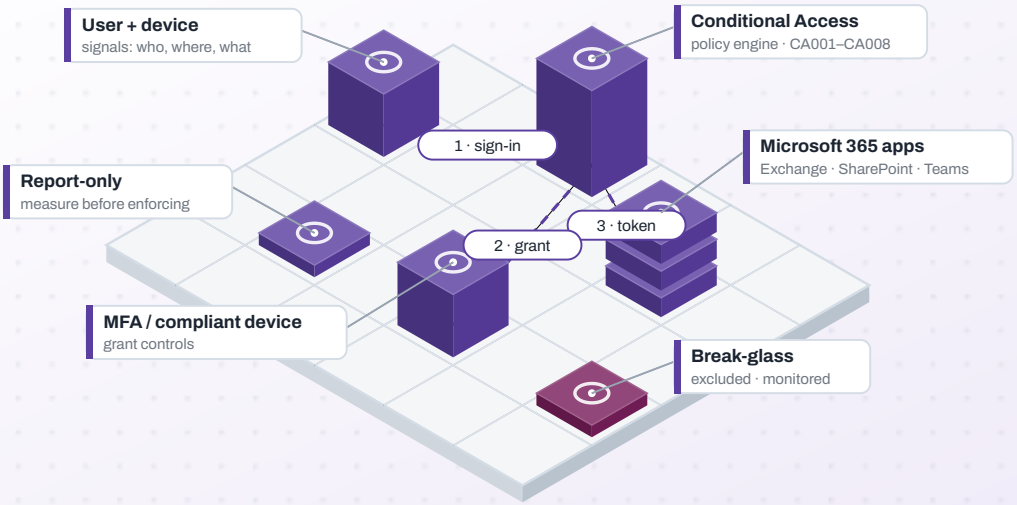
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-ID-001

Building a Conditional Access and MFA Baseline in Microsoft Entra ID

Replace security defaults with a named, testable policy set: emergency access accounts, legacy authentication blocked, MFA for every user, phishing-resistant MFA for administrators and compliant devices for sensitive apps, rolled out report-only first, then pilot, then enforced.

Identity & Access | Conditional Access | Zero Trust



DOCUMENT ID	SOP-ID-001
VERSION	1.0
EFFECTIVE	October 2026
AUDIENCE	Identity administrators, M365 administrators, security engineers, auditors (Chapter 6)
AUTHOR	Richmond Dieujuste, Principal Consultant

Contents

1. Concepts You Need First 3
1.1 How a sign-in is evaluated 3
1.2 Anatomy of a policy 4
1.3 Security defaults versus Conditional Access 5
1.4 Authentication strengths 5
1.5 Emergency access accounts 6
1.6 Choosing a method 6

2. Access, Prerequisites and Planning 8
2.1 Level of access required 8
2.2 Licensing 8
2.3 Prerequisites checklist 8
2.4 Risk and planning notes 9
2.5 Decisions to make up front 9

3. The Baseline Policy Set 10
3.1 Policy specifications 10
3.2 The 14 privileged roles in CA004 11

4. Method A · Building in the Entra Admin Center 12
4.1 Turn on the break-glass sign-in alert 14

5. Method B · Microsoft Graph PowerShell 15
5.1 Connect with least privilege 15
5.2 Read the current state first 15
5.3 Create a policy from a definition 15
5.4 Promote a policy without editing it by hand 16

6. Rollout: Report-only, Pilot, Enforce 17
6.1 Reading report-only results 17
6.2 Using What If before each promotion 18
6.3 Enforcement cut-over 18

7. Verification, Rollback and Troubleshooting 20
7.1 Verification checklist 20
7.2 Rollback 20
7.3 Troubleshooting 21

8. Summary, Glossary and Review 22
8.1 Chapter summary 22
8.2 Glossary 22
8.3 Framework references 23

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain how Conditional Access evaluates a sign-in: signals, assignments, conditions, grant and session controls.
- Create and protect two emergency access (break-glass) accounts before any policy is switched on.
- Build the eight-policy baseline in the Entra admin center and from Microsoft Graph PowerShell, and know which is the version of record.
- Run every policy in report-only mode, read the impact in the sign-in logs and What If, and promote it through pilot to enforcement.
- Troubleshoot the common AADSTS errors and roll a policy back without opening the tenant.

Time	Difficulty	Minimum access	Risk
1 day build · 2–4 weeks staged rollout	Intermediate	Conditional Access Administrator	High if enforced untested; low in report-only

CHAPTER 1

Concepts You Need First

Every sign-in to Microsoft 365 passes through Microsoft Entra ID. **Conditional Access** is the policy engine that sits at that point and decides, sign-in by sign-in, whether to allow it, block it, or allow it only after the user proves something more: a second factor, a compliant device, a fresh password. A baseline is the small, named set of policies that every tenant should have before anything else is built on top of it.

KEY CONCEPT · AN IF-THEN STATEMENT, NOT A FIREWALL

A Conditional Access policy reads like a sentence: *if* a sign-in matches these **assignments** (who and what) and these **conditions** (from where, on what, at what risk), *then* apply these **controls** (block, or grant with requirements). Policies do not run in order and do not override each other: every policy that matches is applied, and all of their requirements must be met. One block anywhere wins.

1.1 How a sign-in is evaluated

Conditional Access runs after first-factor authentication. Entra ID already knows who the user is (password, passkey or federated token); it then collects signals about the sign-in, finds every enabled policy whose assignments and conditions match, and combines their controls. The result is a single decision returned before the token is issued.

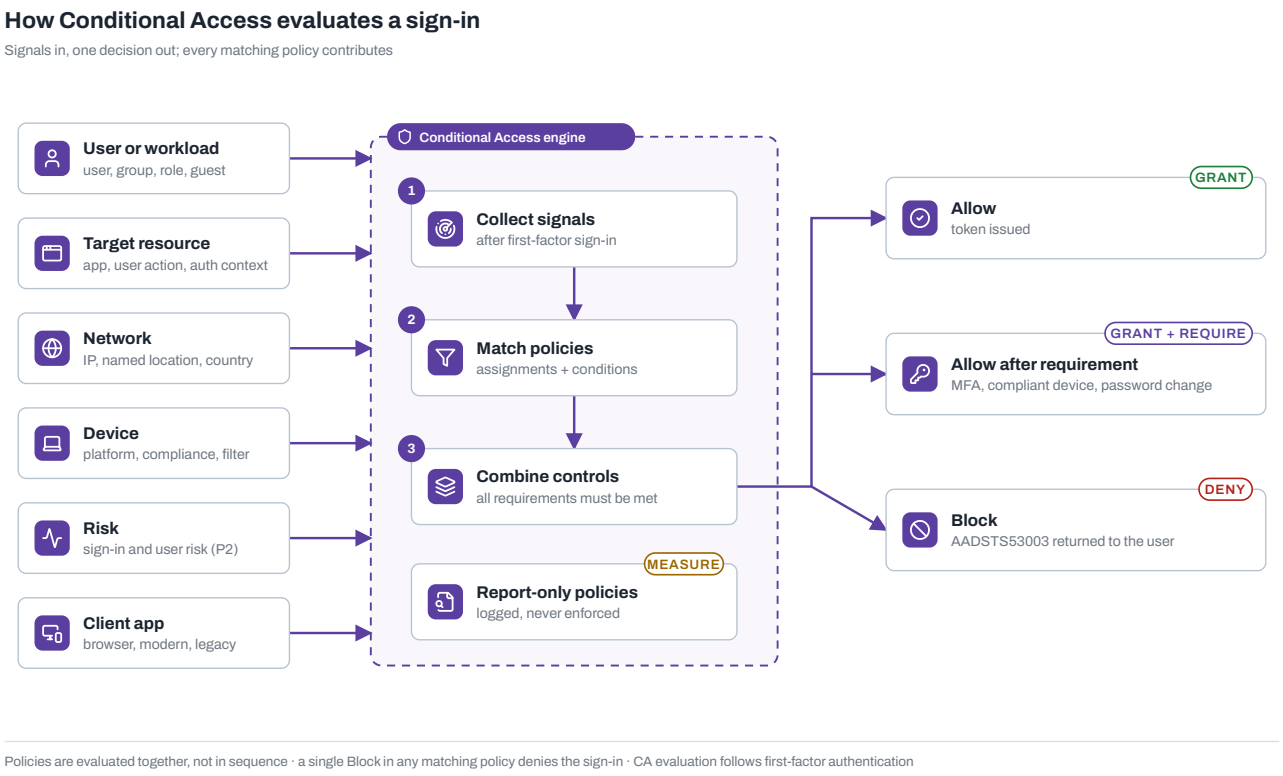


Figure 1. The evaluation model. Signals on the left feed every enabled policy; matching policies combine, and the strictest outcome wins.

1.2 Anatomy of a policy

Every policy has the same four parts. Learn to read a policy in this order and you can review anyone else's tenant in minutes.

Part	What it answers	Baseline example
Assignments · users	Who is in scope, and who is excluded?	*All users*, excluding the two emergency access accounts and the directory-sync service account
Assignments · target resources	Which apps or user actions?	*All resources* (formerly *All cloud apps*), or *Register security information*
Conditions	Under which circumstances?	Client apps = *Exchange ActiveSync* and *Other clients*; device platform; location; risk
Grant / session controls	What must be true to get in, and for how long?	Require authentication strength *Multifactor authentication*; sign-in frequency 12 hours

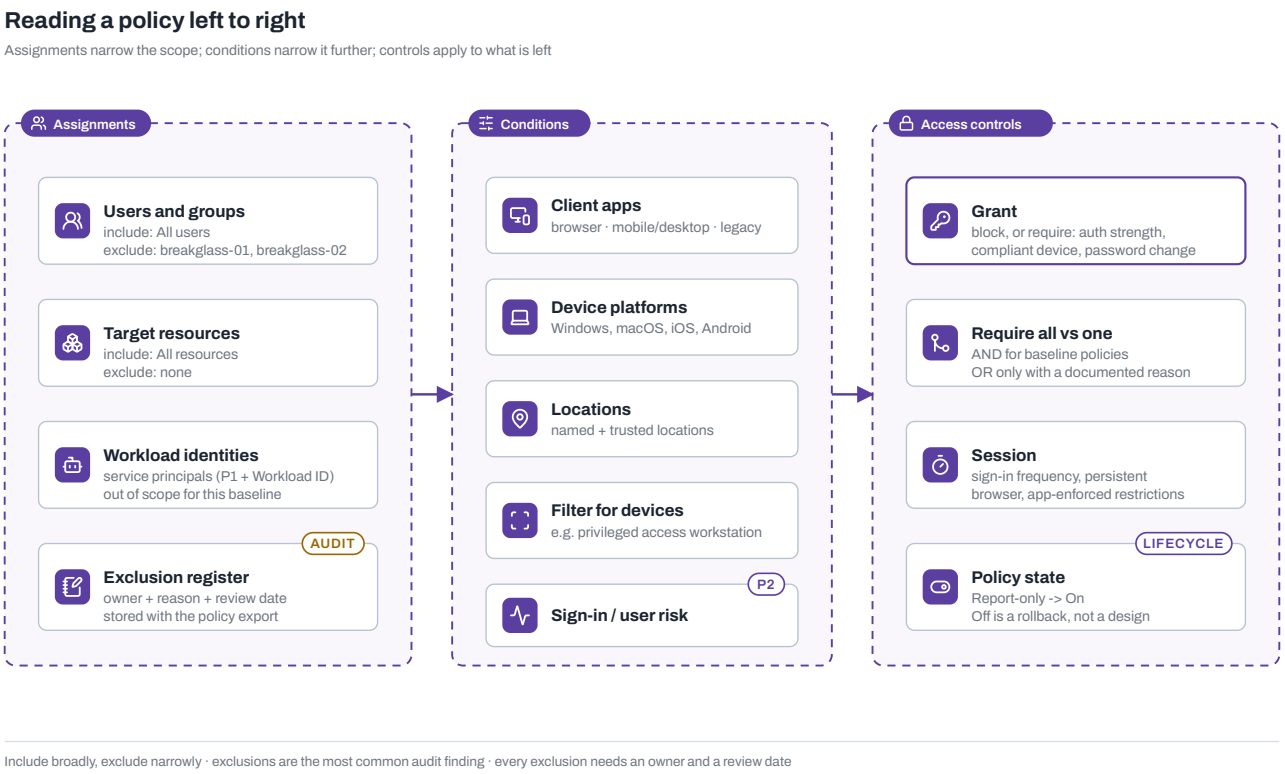


Figure 2. Every policy in this SOP is documented in this order, and the exported JSON follows the same structure.

1.3 Security defaults versus Conditional Access

New tenants ship with **security defaults**: a fixed bundle that requires MFA registration, challenges administrators, and blocks legacy authentication. It is a good floor, but it cannot be tuned, cannot exclude an emergency account, and cannot require a compliant device. The two are mutually exclusive: Conditional Access policies cannot be enabled while security defaults are on. This SOP replaces security defaults with an equivalent-or-stronger baseline, and the order of operations matters: build the baseline in report-only first, then turn security defaults off and the baseline on in the same change window.

> **WATCH OUT · DO NOT LEAVE A GAP**
>
> Turning security defaults off before the replacement policies are enforced leaves the tenant with no MFA requirement at all. The cut-over in Chapter 5 switches both in one maintenance window, with the sign-in logs open.

1.4 Authentication strengths

Older policies used the grant control *Require multifactor authentication*, which accepts any registered second factor, including SMS and voice. **Authentication strengths** let a policy name exactly which methods qualify. Three are built in, and custom strengths can be created for special cases.

Built-in strength	Methods it accepts	Use in this baseline
Multifactor authentication	Any MFA combination, including SMS, voice, Authenticator push, OATH, FIDO2, Windows Hello	CA003 all users (minimum)
Passwordless MFA	Authenticator passwordless phone sign-in, FIDO2 security keys and passkeys, Windows Hello for Business, certificate-based MFA	Optional upgrade for all users
Phishing-resistant MFA	FIDO2 security keys and passkeys, Windows Hello for Business, certificate-based MFA	CA004 administrators (required)

1.5 Emergency access accounts

Any policy that applies to *All users* can, if misconfigured, lock out every administrator. Microsoft's guidance is two **emergency access accounts** (also called break-glass accounts): cloud-only, permanently assigned Global Administrator, protected by phishing-resistant credentials kept offline, excluded from every Conditional Access policy except the one that targets them, and watched by an alert that fires on any sign-in.

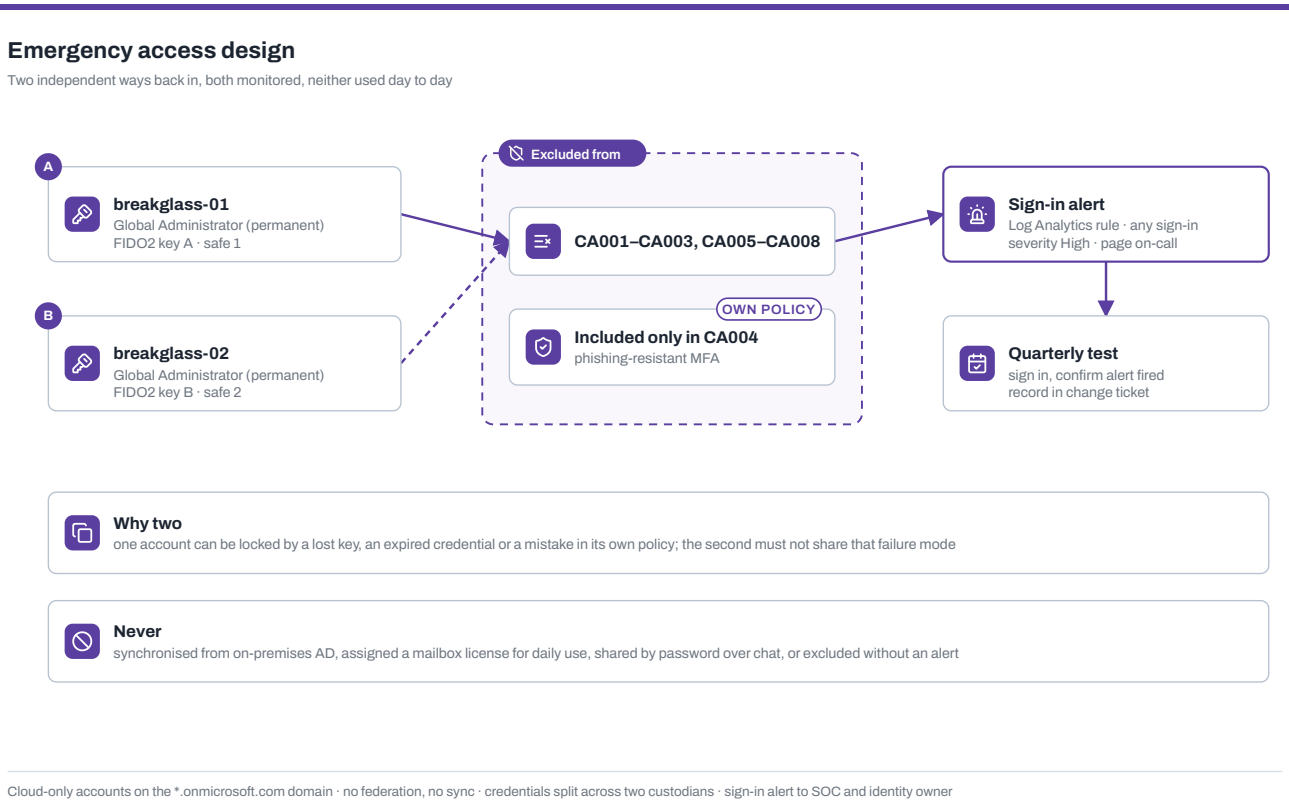


Figure 3. Emergency access accounts are excluded from the baseline but not invisible: every sign-in raises an alert.

1.6 Choosing a method

The baseline can be built three ways. They produce the same policies; what differs is repeatability and evidence.

Method	Best for	Evidence produced
A · Entra admin center	Learning the model; small tenants; one-off changes	Audit log entries and screenshots
B · Microsoft Graph PowerShell	Repeatable builds across tenants; peer review of JSON before change	Versioned JSON exports, script transcript
C · Templates in the portal	Fast start from Microsoft's *Secure foundation* and *Zero Trust* templates	Same as A; review every template before saving

GOOD PRACTICE · ONE VERSION OF RECORD

Whichever method builds the policies, the exported JSON in the change repository is the version of record. The portal is where you look; the export is what you review, diff and restore from.

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Task	Minimum role	Notes
Read policies, sign-in logs, What If	Global Reader or Security Reader	Use for reviews and audits; cannot change anything.
Create, edit, delete policies; named locations; authentication strengths	Conditional Access Administrator	Activate through PIM for the change window only.
Create emergency access accounts and assign Global Administrator	Privileged Role Administrator + User Administrator	Or Global Administrator; two-person rule recommended.
Disable security defaults	Conditional Access Administrator or Security Administrator	Entra ID › Overview › Properties › Manage security defaults.
Authentication methods policy (FIDO2, Authenticator)	Authentication Policy Administrator	Needed before phishing-resistant MFA can be required.
Log Analytics alert for break-glass sign-in	Log Analytics Contributor + Monitoring Contributor	Requires Entra sign-in logs exported to a workspace.

2.2 Licensing

Conditional Access requires **Microsoft Entra ID P1** for every user the policies protect (included in Microsoft 365 E3, E5 and Business Premium). Risk-based conditions (sign-in risk, user risk) require **Entra ID P2** (Microsoft 365 E5 or the Entra ID Governance / Suite add-ons). The baseline in this SOP uses P1 features only; CA008 is the optional P2 policy.

2.3 Prerequisites checklist

- [ ] Change ticket approved, with a maintenance window for the enforcement cut-over (Chapter 5).
- [ ] Sign-in and audit logs exported to a Log Analytics workspace (diagnostic setting on Entra ID) and retained at least 90 days.
- [ ] Inventory of service accounts and integrations that sign in non-interactively (scanners, SMTP relays, sync accounts).
- [ ] Inventory of legacy-protocol use: Entra ID › Sign-in logs, filter *Client app = Other clients / Exchange ActiveSync*, last 30 days.
- [ ] Authentication methods policy enables Microsoft Authenticator and FIDO2 security keys / passkeys for the target groups.
- [ ] Every administrator owns a phishing-resistant credential (FIDO2 key, passkey or Windows Hello for Business) before CA004 is enforced.

- [ ] Intune compliance policies assigned and reporting for the device platforms CA006 will require.
- [ ] Pilot group created (`CA-Pilot`, 10–30 users across departments, including at least one executive assistant and one field user).
- [ ] Communications drafted: what users will see, when, and how to reach the service desk.

2.4 Risk and planning notes

Action	Risk	Notes
Create policies in report-only	READ-ONLY	No user impact. Always first.
Create emergency access accounts	LOW	Store credentials before enabling any policy.
Enforce CA001 block legacy auth	MODERATE	Breaks old mail clients, scanners and scripts using basic auth. Inventory first.
Enforce CA003 MFA for all users	MODERATE	Users without a registered method are prompted to register; spike in service desk calls.
Enforce CA004 phishing-resistant MFA for admins	HIGH	An admin without a key is locked out of admin portals. Verify registration per admin.
Enforce CA006 compliant device	HIGH	Unenrolled or non-compliant devices lose access to the targeted apps.
Turn security defaults off	HIGH	Only in the same window as enforcement; never on its own.

2.5 Decisions to make up front

Decision	Options	Baseline choice
Naming convention	Free text, or ID + scope + control	`CA003-AllUsers-AllApps-RequireMFA`
Trusted locations	None; office egress IPs; countries	Office egress IPs as a named location, used for *reporting*, not to skip MFA
Allowed countries	Global; allow-list; block-list	Block-list of countries with no business presence (CA007), reviewed quarterly
Admin scope	Directory roles; a group; both	Directory roles (14 privileged roles), so new admins are covered automatically
Guests	Same as members; separate policy	In scope of CA003 via *All users*; resource tenant enforces MFA
Device compliance target	All apps; sensitive apps only	Sensitive apps only at first (SharePoint, Exchange), expanding later

CHAPTER 3

The Baseline Policy Set

Eight policies, each doing one job. Small, single-purpose policies are easier to test, explain to an auditor and roll back than a few large ones. CA001 to CA006 are the baseline; CA007 is recommended; CA008 needs Entra ID P2.

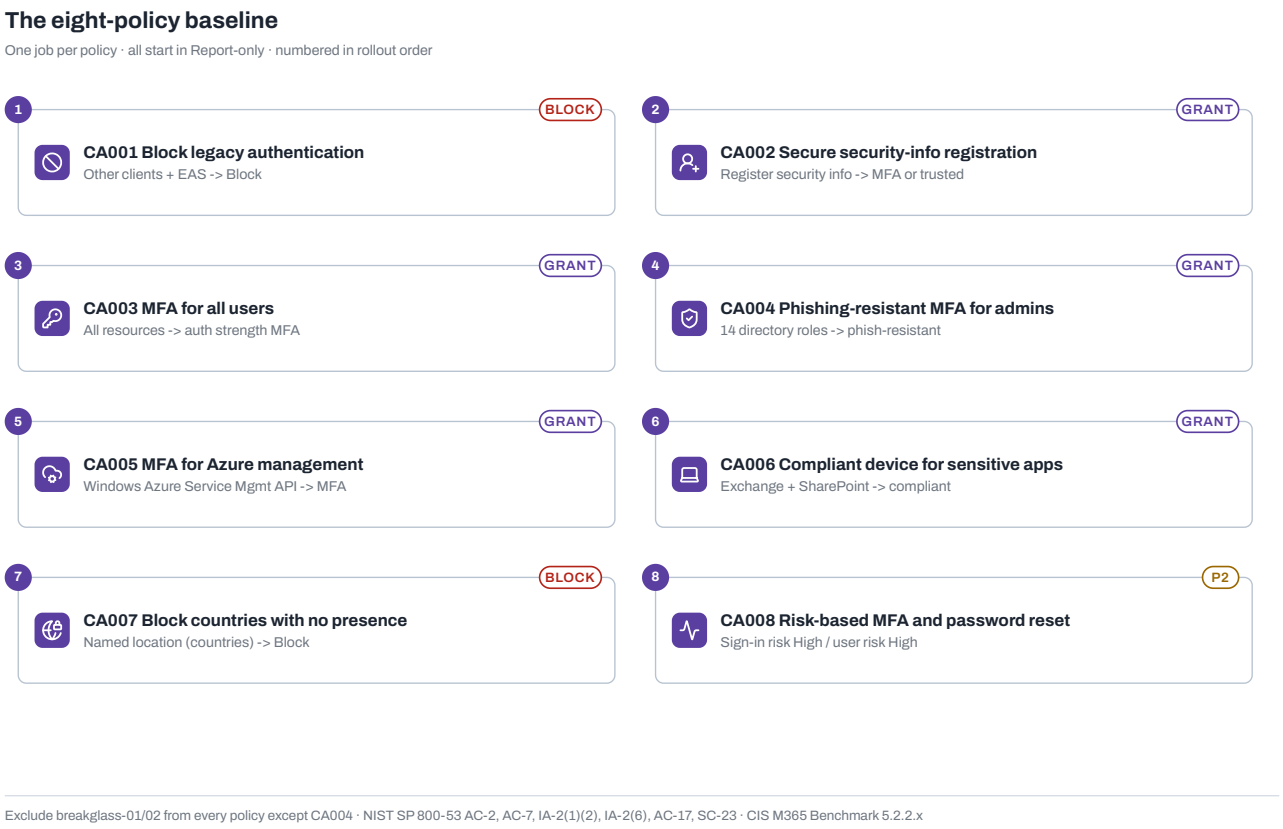


Figure 4. The baseline. Each card is one policy in the tenant and one JSON file in the change repository.

3.1 Policy specifications

The table is the specification the build is checked against. *Users* shows include / exclude; every policy excludes the two emergency access accounts unless stated.

Policy	Users	Target resources and conditions	Grant / session
CA001-AllUsers-LegacyAuth-Block	All users / BG accounts	All resources · client apps: Exchange ActiveSync, Other clients	Block
CA002-AllUsers-SecurityInfo-Register	All users / BG, guests	User action: Register security information · locations: any, exclude trusted office IPs	Require auth strength MFA

Policy	Users	Target resources and conditions	Grant / session
CA003-AllUsers-AllApps-RequireMFA	All users / BG, directory sync account	All resources	Require auth strength MFA
CA004-Admins-AllApps-PhishResistant	14 privileged roles (incl. BG accounts via role)	All resources	Require auth strength Phishing-resistant MFA · sign-in frequency 4 h
CA005-AllUsers-AzureMgmt-RequireMFA	All users / BG	Windows Azure Service Management API	Require auth strength MFA · sign-in frequency every time
CA006-AllUsers-Sensitive-Compliant	All users / BG, guests	Office 365 Exchange Online, Office 365 SharePoint Online · platforms: Windows, macOS, iOS, Android	Require compliant device
CA007-AllUsers-BlockedCountries-Block	All users / BG, travel exception group	All resources · locations: include *Blocked countries*	Block
CA008-AllUsers-Risk-Remediate	All users / BG	All resources · sign-in risk High; separate policy for user risk High	MFA (sign-in risk) · secure password change (user risk)

WHY · WHY CA004 INCLUDES THE EMERGENCY ACCOUNTS

The emergency accounts hold Global Administrator, so a role-based policy picks them up automatically. That is intended: they are protected by phishing-resistant keys, so CA004 is the one policy they can always satisfy. Keep them excluded from every other policy so that no single misconfiguration can lock both out.

3.2 The 14 privileged roles in CA004

Target directory roles rather than a group so that anyone activated into a role through PIM is covered the moment the role is active. Microsoft's *Require phishing-resistant MFA for administrators* template uses this list:

Roles	
Global Administrator · Privileged Role Administrator · Privileged Authentication Administrator	Security Administrator · Conditional Access Administrator · Exchange Administrator
SharePoint Administrator · User Administrator · Helpdesk Administrator	Billing Administrator · Authentication Administrator · Application Administrator
Cloud Application Administrator · Password Administrator	

CHAPTER 4

Method A · Building in the Entra Admin Center

Work through the steps in order. Every policy is saved as **Report-only**. Nothing in this chapter changes what users experience.

STEP 1 Create and protect the emergency access accounts

1. Sign in to the Microsoft Entra admin center as a Privileged Role Administrator. Go to `Entra ID` › `Users` › `New user` › `Create new user`.
2. User principal name `breakglass-01@<tenant>.onmicrosoft.com`; display name *Emergency Access 01*. Untick `Account enabled` only if your process enables it on use; otherwise leave it enabled. Repeat for `breakglass-02`.
3. Open each account › `Assigned roles` › `Add assignments` › *Global Administrator*, assignment type **Active**, **permanent** (not eligible).
4. Register a FIDO2 security key for each account (sign in at `https://aka.ms/mysecurityinfo` as the account on a clean workstation). Store key A and key B in separate safes with separate custodians.
5. Record both accounts, custodians and safe locations in the identity runbook. Do not record passwords there.

STEP 2 Create the named locations

1. Go to `Entra ID` › `Conditional Access` › `Named locations` › `+ IP ranges location`. Name *Office egress*, add the public egress IPs in CIDR form, tick `Mark as trusted location`.
2. Select `+ Countries location`. Name *Blocked countries*; choose the countries with no business presence. Leave `Include unknown countries/regions` unticked unless you have tested it with mobile carriers.
3. Create a group `CA-Exclude-TravelException` for approved travel; each membership needs an end date in the access request.

STEP 3 Build CA001 · Block legacy authentication

1. Go to `Conditional Access` › `Policies` › `+ New policy`. Name `CA001-AllUsers-LegacyAuth-Block`.
2. `Users` › Include `All users`. Exclude › `Users and groups` › select `breakglass-01`, `breakglass-02`.
3. `Target resources` › `Resources (formerly cloud apps)` › Include `All resources`.
4. `Conditions` › `Client apps` › Configure **Yes**; tick only `Exchange ActiveSync clients` and `Other clients`.

5. Grant › Block access › Select.
6. Enable policy › **Report-only** › Create.

Report-only is the third option on the Enable policy toggle. If the page says policies cannot be enabled while security defaults are on, saving in Report-only still works.

STEP 4 Build CA003 · MFA for all users

1. New policy `CA003-AllUsers-AllApps-RequireMFA`. Users: include All users; exclude the two emergency accounts and the directory synchronization account (*On-Premises Directory Synchronization Service Account* is excluded by role).
2. Target resources: All resources.
3. Grant › Grant access › tick Require authentication strength › *Multifactor authentication*.
4. Leave session controls empty. Enable policy **Report-only** › Create.

STEP 5 Build CA004 · Phishing-resistant MFA for administrators

1. New policy `CA004-Admins-AllApps-PhishResistant`. Users › Include Select users and groups › Directory roles › tick the 14 roles in section 3.3.
2. Do **not** exclude the emergency accounts here (see the *Why* note in Chapter 3).
3. Target resources: All resources. Grant › Require authentication strength › *Phishing-resistant MFA*.
4. Session › Sign-in frequency › *Periodic reauthentication* 4 hours.
5. Enable policy **Report-only** › Create.

STEP 6 Build CA002, CA005, CA006 and CA007

1. **CA002**: Target resources › User actions › Register security information. Conditions › Locations include *Any location*, exclude *All trusted locations*. Grant › authentication strength *Multifactor authentication*. Exclude guests (Users › Exclude › Guest or external users).
2. **CA005**: Target resources › Select resources › *Windows Azure Service Management API*. Grant › authentication strength MFA. Session › sign-in frequency Every time.
3. **CA006**: Target resources › *Office 365 Exchange Online* and *Office 365 SharePoint Online*. Conditions › Device platforms › Windows, macOS, iOS, Android. Grant › Require device to be marked as compliant.
4. **CA007**: Target resources › All resources. Conditions › Locations › Include Selected locations › *Blocked countries*. Exclude group `CA-Exclude-TravelException`. Grant › Block.

5 Save each one as **Report-only**.

GOOD PRACTICE · USE THE TEMPLATES AS A CROSS-CHECK, NOT A SHORTCUT

Conditional Access › Policies › + New policy from template › *Secure foundation* contains Microsoft's current versions of CA001, CA003, CA004 and CA005. Open them side by side with your policies after the build; differences are either deliberate (document them) or mistakes (fix them).

4.1 Turn on the break-glass sign-in alert

With sign-in logs flowing to Log Analytics, create an alert rule so that any use of an emergency account is noticed within minutes. In the workspace › Alerts › Create › Alert rule › Custom log search:

ALERT RULE QUERY · EMERGENCY ACCESS SIGN-IN — KQL

```
// Any sign-in attempt by an emergency access account, success or failure
SigninLogs
| where UserPrincipalName in~ ("breakglass-01@contoso.onmicrosoft.com",
                               "breakglass-02@contoso.onmicrosoft.com")
| project TimeGenerated, UserPrincipalName, ResultType, ResultDescription,
          IPAddress, Location, AppDisplayName, ConditionalAccessStatus
```

Evaluate every 5 minutes over the last 5 minutes; threshold *greater than 0*; severity 1 (Error); action group that pages the on-call identity engineer and emails the security mailbox.

CHAPTER 5

Method B · Microsoft Graph PowerShell

The same policies, built from JSON. This is the method of record for repeatable builds: the JSON is peer-reviewed in the change request, the script creates every policy in report-only, and the export after the change becomes the new baseline in the repository.

5.1 Connect with least privilege

CONNECT · DELEGATED, SCOPED — POWERSHELL

```powershell
# Microsoft Graph PowerShell SDK v2
Install-Module Microsoft.Graph -Scope CurrentUser   # once
Connect-MgGraph -Scopes "Policy.Read.All","Policy.ReadWrite.ConditionalAccess","Application.Read.All" -
NoWelcome
Get-MgContext | Select-Object Account, TenantId, Scopes
```

5.2 Read the current state first

INVENTORY EXISTING POLICIES AND EXPORT THEM — POWERSHELL

```powershell
$stamp = Get-Date -Format yyyyMMdd-HHmm
$dir   = "C:\CA-Baseline\export-$stamp"; New-Item $dir -ItemType Directory | Out-Null
Get-MgIdentityConditionalAccessPolicy -All |
  ForEach-Object {
    $_ | ConvertTo-Json -Depth 10 | Out-File "$dir\$($_.DisplayName).json" -Encoding utf8
    [pscustomobject]@{ Name = $_.DisplayName; State = $_.State; Modified = $_.ModifiedDateTime }
  } | Format-Table -AutoSize
```

5.3 Create a policy from a definition

Each policy is a hashtable mirroring the Graph `conditionalAccessPolicy` resource. The example builds CA001; the others follow the same pattern with different conditions and controls.

CA001 · BLOCK LEGACY AUTHENTICATION (REPORT-ONLY) — POWERSHELL

```powershell
$bg = (Get-MgUser -Filter "startswith(userPrincipalName,'breakglass-')").Id

$ca001 = @{
  displayName = "CA001-AllUsers-LegacyAuth-Block"
  state       = "enabledForReportingButNotEnforced"     # report-only
  conditions  = @{
    users          = @{ includeUsers = @("All"); excludeUsers = $bg }
    applications   = @{ includeApplications = @("All") }
    clientAppTypes = @("exchangeActiveSync","other")
  }
  grantControls = @{ operator = "OR"; builtInControls = @("block") }
}
New-MgIdentityConditionalAccessPolicy -BodyParameter $ca001
```

CA004 · PHISHING-RESISTANT MFA FOR ADMINISTRATORS POWERSHELL

```powershell
# Built-in authentication strength IDs are fixed across tenants
$phishResistant = "00000000-0000-0000-0000-000000000004"
$roles = @(
 "62e90394-69f5-4237-9190-012177145e10", # Global Administrator
 "e8611ab8-c189-46e8-94e1-60213ab1f814", # Privileged Role Administrator
 "7be44c8a-adaf-4e2a-84d6-ab2649e08a13", # Privileged Authentication Administrator
 "194ae4cb-b126-40b2-bd5b-6091b380977d", # Security Administrator
 "b1be1c3e-b65d-4f19-8427-f6fa0d97feb9", # Conditional Access Administrator
 "29232cdf-9323-42fd-ade2-1d097af3e4de", # Exchange Administrator
 "f28a1f50-f6e7-4571-818b-6a12f2af6b6c", # SharePoint Administrator
 "fe930be7-5e62-47db-91af-98c3a49a38b1", # User Administrator
 "729827e3-9c14-49f7-bb1b-9608f156bbb8", # Helpdesk Administrator
 "b0f54661-2d74-4c50-afa3-1ec803f12efe", # Billing Administrator
 "c4e39bd9-1100-46d3-8c65-fb160da0071f", # Authentication Administrator
 "9b895d92-2cd3-44c7-9d02-a6ac2d5ea5c3", # Application Administrator
 "158c047a-c907-4556-b7ef-446551a6b5f7", # Cloud Application Administrator
 "966707d0-3269-4727-9be2-8c3a10f19b9d"  # Password Administrator
)
$ca004 = @{
  displayName = "CA004-Admins-AllApps-PhishResistant"
  state       = "enabledForReportingButNotEnforced"
  conditions  = @{
    users        = @{ includeRoles = $roles }
    applications = @{ includeApplications = @("All") }
  }
  grantControls  = @{ operator = "OR"; authenticationStrength = @{ id = $phishResistant } }
  sessionControls = @{ signInFrequency = @{ isEnabled = $true; type = "hours"; value = 4 } }
}
New-MgIdentityConditionalAccessPolicy -BodyParameter $ca004
```

NOTE · AUTHENTICATION STRENGTH IDS

The three built-in strengths have fixed IDs: `...0002` Multifactor authentication, `...0003` Passwordless MFA, `...0004` Phishing-resistant MFA. Confirm in your tenant with `Get-MgPolicyAuthenticationStrengthPolicy | Select DisplayName, Id`.

5.4 Promote a policy without editing it by hand

CHANGE STATE ONLY · REPORT-ONLY -> ON POWERSHELL

```powershell
$p = Get-MgIdentityConditionalAccessPolicy -Filter "displayName eq 'CA001-AllUsers-LegacyAuth-Block'"
Update-MgIdentityConditionalAccessPolicy -ConditionalAccessPolicyId $p.Id -State "enabled"
# Rollback is the same call with -State "enabledForReportingButNotEnforced"
```

WATCH OUT · NEVER PASTE SECRETS OR TOKENS INTO SCRIPTS

Use delegated sign-in with PIM-activated roles for interactive changes. Automation pipelines use a workload identity with certificate credentials and the minimum Graph application permissions; never a user account with a stored password.

CHAPTER 6

Rollout: Report-only, Pilot, Enforce

Every policy moves through the same three gates. A policy only moves forward when the evidence for the current gate is in the change ticket.

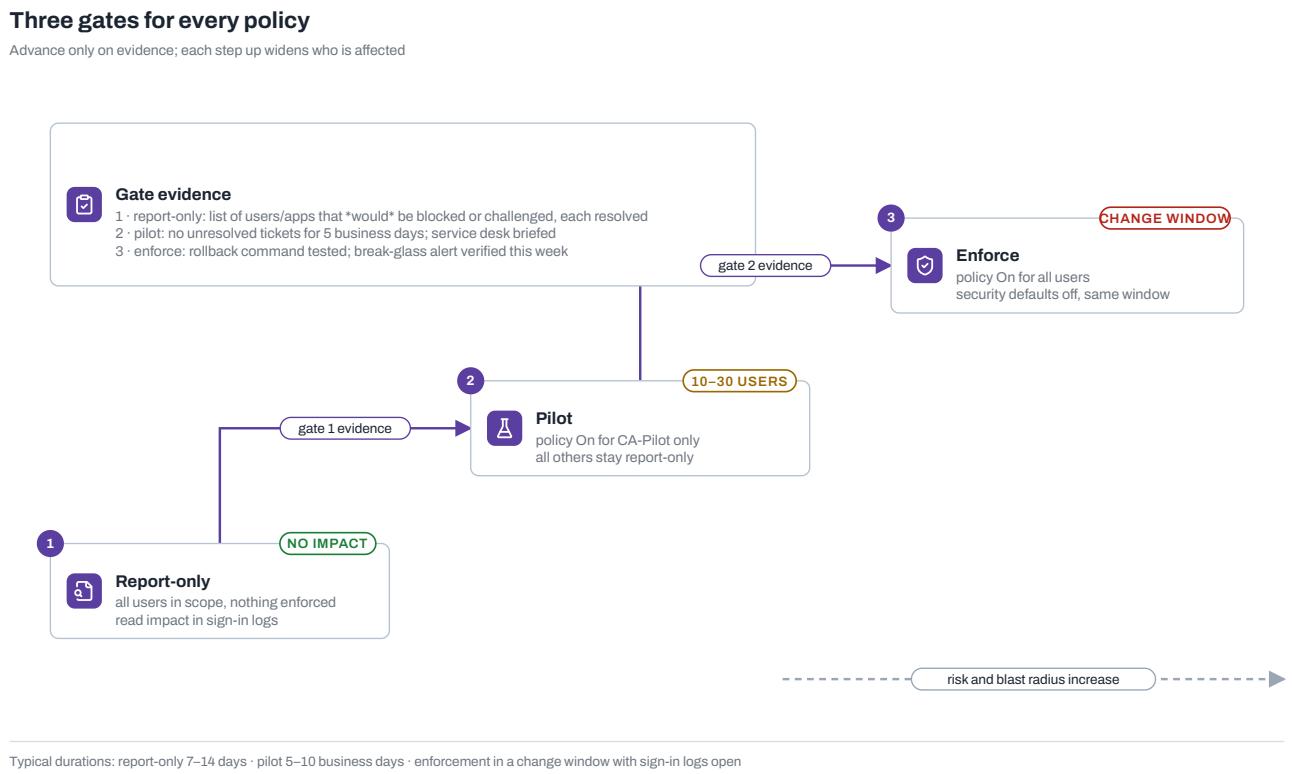


Figure 5. Report-only first, then a pilot group, then everyone. The same ladder applies to every policy in the set.

6.1 Reading report-only results

In `Entra ID` › `Monitoring & health` › `Sign-in logs`, open any sign-in and select the `Report-only` tab. Each policy shows one of: *Report-only: Success* (requirements would have been met), *Report-only: Failure* (would have been blocked), *Report-only: User action required* (would have prompted for MFA or compliance), or *Not applied*.

At scale, use the **Conditional Access insights and reporting** workbook (`Conditional Access` › `Insights and reporting`), or query the workspace directly:

REPORT-ONLY IMPACT PER POLICY, LAST 14 DAYS KQL

```
SigninLogs
| where TimeGenerated > ago(14d)
| mv-expand CAP = ConditionalAccessPolicies
| extend Policy = tostring(CAP.displayName), Result = tostring(CAP.result)
| where Policy startswith "CA0" and Result in ("reportOnlyFailure","reportOnlyInterrupted")
| summarize Users = dcount(UserPrincipalName), SignIns = count(),
            Apps = make_set(AppDisplayName, 10) by Policy, Result
| order by Policy asc
```

WHO STILL USES LEGACY AUTHENTICATION (CA001 IMPACT) KQL

```
SigninLogs
| where TimeGenerated > ago(30d)
| where ClientAppUsed in ("Exchange ActiveSync","Other clients","IMAP4","POP3",
                          "Authenticated SMTP","Exchange Web Services","MAPI Over HTTP")
| summarize LastSeen = max(TimeGenerated), Count = count()
          by UserPrincipalName, ClientAppUsed, AppDisplayName
| order by Count desc
```

WORKED EXAMPLE · A SCANNER THAT SENDS BY SMTP

The legacy-auth query shows a multifunction printer account signing in with *Authenticated SMTP* every few minutes. Blocking it breaks scan-to-email. The fix is not an exclusion: move the device to an SMTP relay connector in Exchange Online or to High Volume Email, then confirm the account disappears from the query before CA001 is enforced.

6.2 Using What If before each promotion

Conditional Access › Policies › What If simulates a sign-in for a chosen user, app, platform, location and client app, and lists the policies that would apply and the ones that would not, with the reason. Run it for: a standard user, a pilot user, an administrator, each emergency account, a guest, and the directory-sync account. Paste the results into the ticket.

6.3 Enforcement cut-over

STEP 1 Enforce the baseline in one change window

1. Confirm gate evidence for every policy is in the ticket and the break-glass alert fired during this week's test sign-in.
2. Activate *Conditional Access Administrator* through PIM. Open a second browser profile signed in as a test user, and the sign-in logs in a third tab.
3. Switch CA001, CA002, CA003, CA005 to **On** (state `enabled`).
4. Entra ID › Overview › Properties › Manage security defaults › **Disabled** › reason *My organization is using Conditional Access*.

5. Sign in as the test user to Outlook on the web and Teams: expect an MFA prompt. Sign in as a test administrator with a FIDO2 key: expect success.
6. Switch CA004 to **On**, then CA006 and CA007, re-testing after each. Leave CA008 report-only unless P2 is licensed and reviewed.
7. Export all policies (Method B) and commit the export to the change repository as the new version of record.

If anything unexpected appears in the sign-in logs, set that one policy back to report-only (Chapter 6.2) and continue with the rest.

CHAPTER 7

Verification, Rollback and Troubleshooting

7.1 Verification checklist

Check	How	Expected
Security defaults off, CA on	Entra ID › Properties	*Security defaults: Disabled*; eight CA policies listed
Policy states	`Get-MgIdentityConditionalAccessPolicy | select DisplayName,State`	CA001–CA007 `enabled`; CA008 per decision
Emergency exclusions	What If as breakglass-01	Only CA004 applies
Legacy auth blocked	Sign-in logs, client app *Other clients*, last 24 h	All results *Failure*, error 53003
MFA enforced	Sign-in logs, *Authentication requirement*	*Multifactor authentication* for interactive sign-ins
Admins phishing-resistant	Sign-in logs, admin portals, *Authentication details*	FIDO2 / passkey / Windows Hello for every admin sign-in
Break-glass alert	Quarterly test sign-in	Alert received within 10 minutes
Evidence	Change repository	JSON export dated today, matches portal

7.2 Rollback

Rollback means returning one policy to report-only, not deleting it and not re-enabling security defaults. Report-only keeps the policy's logging, so the problem can be investigated with real data.

Situation	Action	Time to effect
One policy blocks a business-critical app	Set that policy to Report-only (portal or `Update-MgIdentityConditionalAccessPolicy -State enabledForReportingButNotEnforced`)	New sign-ins immediately; existing tokens until refresh
All administrators locked out	Sign in as breakglass-01 with FIDO2 key A; fix the policy; record the use; rotate nothing unless the key was exposed	Minutes
Policy deleted by mistake	Restore from the JSON export: `New-MgIdentityConditionalAccessPolicy -BodyParameter (Get-Content x.json | ConvertFrom-Json -AsHashtable)` after removing read-only properties (`id`, `createdDateTime`, `modifiedDateTime`, `templateId`)	Minutes; recreated in report-only first

7.3 Troubleshooting

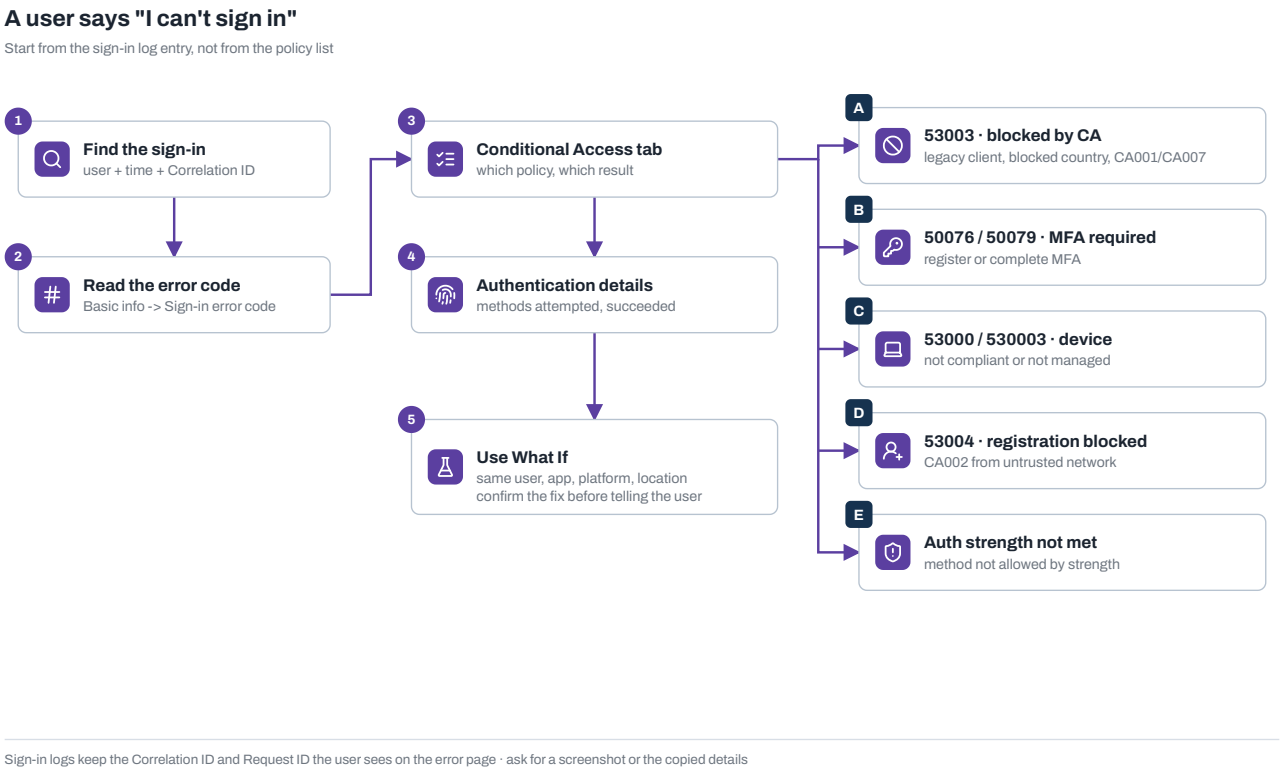


Figure 6. Troubleshooting runs from the sign-in log entry outwards. The error code narrows the cause to one of five families.

Symptom	Likely cause	Fix
Outlook 2013 / old iOS Mail keeps prompting, then fails	Basic authentication blocked by CA001	Update the client to modern authentication (Outlook 2016+, current iOS Mail / Outlook mobile).
"You can't get there from here" on a personal Mac	CA006 requires a compliant device	Enroll the device (SOP-EM-002) or use the web apps from a managed device.
Admin portal: "Your sign-in method isn't allowed"	CA004 needs phishing-resistant MFA; user tried push	Sign in with the FIDO2 key or passkey; register one if missing.
New starter cannot register MFA from home	CA002 allows registration only from trusted locations or with existing MFA	Issue a Temporary Access Pass (one-time, 8 hours) so registration satisfies CA002.
Service account sign-ins failing after CA003	Non-interactive account in *All users* scope	Replace with a workload identity (service principal, certificate). Exclusion only as a dated exception.
Report-only shows thousands of *Failure* for CA006	Devices not enrolled or compliance not yet evaluated	Expand Intune enrollment first; do not enforce CA006 until the numbers drop.

CHAPTER 8

Summary, Glossary and Review

8.1 Chapter summary

- Conditional Access combines every matching policy; requirements add up and a single block wins.
- Build the baseline before touching security defaults, and switch the two in one change window.
- Two emergency access accounts are excluded from everything except phishing-resistant MFA, and any use raises an alert.
- Eight single-purpose policies: block legacy auth, protect registration, MFA for everyone, phishing-resistant MFA for admins, MFA for Azure management, compliant devices for sensitive apps, block unused countries, and risk-based remediation with P2.
- Every policy goes report-only › pilot › enforce, with evidence at each gate.
- Rollback is a state change to report-only; the JSON export is the version of record.

Check your understanding

1. Two policies apply to a sign-in: one requires MFA and one requires a compliant device. What must the user satisfy?
2. Why is CA004 targeted at directory roles rather than at an *Admins* group?
3. What is the difference between *Report-only: Failure* and *Report-only: User action required*?
4. A multifunction printer stops sending scans after CA001 is enforced. What is the correct fix, and why is an exclusion the wrong one?
5. Write the PowerShell call that returns CA003 to report-only.

8.2 Glossary

Conditional Access	Entra ID policy engine that evaluates signals at sign-in and returns allow, allow-with-requirements, or block.
Report-only	Policy state `enabledForReportingButNotEnforced`: evaluated and logged, never enforced.
Authentication strength	Named set of allowed authentication method combinations used as a grant control.
Phishing-resistant MFA	Methods bound to the origin so credentials cannot be replayed: FIDO2 / passkeys, Windows Hello for Business, certificate-based authentication.
Emergency access account	Cloud-only Global Administrator excluded from most policies, used only when normal admin access fails.
Legacy authentication	Protocols that send a username and password without a modern token flow (POP, IMAP, SMTP AUTH, older EAS, EWS basic).

Named location	IP ranges or countries defined once and referenced by policies.
Temporary Access Pass	Time-limited passcode that satisfies MFA so a user can register a strong method.
What If	Policy simulator that lists which policies would apply to a described sign-in.

8.3 Framework references

Framework	Controls addressed
NIST SP 800-53 Rev. 5	AC-2 Account Management · AC-7 Unsuccessful Logon Attempts · AC-17 Remote Access · IA-2(1)(2) MFA for privileged and non-privileged accounts · IA-2(6) access to accounts with separate device · SC-23 Session Authenticity
CIS Microsoft 365 Foundations	5.2.2.x Conditional Access recommendations (MFA for admins and all users, block legacy authentication, sign-in frequency)
CISA SCuBA (Entra ID)	MS.AAD.1 legacy authentication · MS.AAD.3 strong authentication · MS.AAD.7 privileged access
FDA 21 CFR Part 11	§11.10(d) limiting system access to authorized individuals · §11.300 controls for identification codes and passwords